

UAS (UJIAN AKHIR SEMESTER) 2025 JARINGAN KOMPUTER LANJUTAN

Nama: Ihsanta Zaki Sanjaya

NRP: 3223600058

Kelas: 3 TKB / 4 TKA

Soal yang dipilih:

3, 5, 7, 9

3. Analisis Keamanan WPA3 (C4- Analisis)

Jelaskan secara teknis perbedaan *key management* antara WPA2 dan WPA3. Analisis skenario di mana serangan *brute-force* masih mungkin dilakukan, serta solusi peningkatan keamanan tanpa mengganti protokol.

 **Indikator:** Analisis protokol, penalaran enkripsi, solusi rekayasa.

Bobot: Teori 50% – Analisis 50%

Jawab:

WPA3 (Wi-Fi Protected Access 3) merupakan generasi terbaru dari protokol keamanan Wi-Fi yang diperkenalkan oleh Wi-Fi Alliance pada tahun 2018 sebagai penerus WPA2. Evolusi protokol keamanan wireless dimulai dari WEP (Wired Equivalent Privacy) yang diperkenalkan tahun 1997 dengan enkripsi kunci statis 64-128 bit yang kemudian terbukti rentan terhadap serangan. WPA hadir tahun 2003 dengan TKIP (Temporal Key Integrity Protocol) yang mengubah kunci secara dinamis dan menggunakan kunci 256 bit, namun masih memiliki celah keamanan yang dieksploitasi. WPA2 yang diperkenalkan tahun 2004 menggunakan AES-CCMP (Counter Mode with Cipher Block Chaining Message Authentication Code Protocol) dengan mekanisme enkripsi yang lebih kuat, namun rentan terhadap serangan KRACK (Key Reinstallation Attack). WPA3 hadir dengan perbaikan fundamental dalam mekanisme autentikasi dan pertukaran kunci, mengatasi kelemahan-kelemahan yang ditemukan pada protokol pendahulunya, serta menyediakan perlindungan yang lebih robust terhadap berbagai jenis serangan modern termasuk serangan brute-force dan offline dictionary attacks.

Perbedaan mendasar dalam key management antara WPA2 dan WPA3 terletak pada mekanisme autentikasi dan proses pembentukan kunci enkripsi.

- WPA2 menggunakan metode Pre-Shared Key (PSK) di mana pengguna memasukkan password yang sama untuk autentikasi dan mendapatkan akses ke jaringan, sementara semua perangkat yang terhubung ke jaringan yang sama berbagi kunci enkripsi yang sama. Mekanisme four-way handshake pada WPA2 menggunakan Pairwise Master Key (PMK) yang diturunkan langsung dari PSK, kemudian menghasilkan Pairwise Transient Key (PTK) untuk enkripsi data.
- WPA3 memperkenalkan protokol SAE (Simultaneous Authentication of Equals) atau Dragonfly yang memberikan perlindungan lebih kuat terhadap serangan offline dictionary dan password-guessing. Dalam WPA3-Personal, SAE menggunakan dua metode untuk menurunkan Password Element: Hunting and Pecking (HnP) dan Hash-to-Element (H2E), dengan H2E menjadi mandatory untuk Wi-Fi 6E (6 GHz) dan Wi-Fi 7 karena HnP rentan terhadap brute force dictionary attacks. Pada WPA3-Enterprise, key management menggunakan 802.1X dengan SHA-256 sebagai Authentication and Key Management (AKM), menggantikan SHA-1 yang digunakan WPA2, serta dapat menggunakan enkripsi 192-bit dengan GCMP-256 untuk data sensitif. Keunggulan utama WPA3 adalah menyediakan enkripsi data individual untuk setiap perangkat

Selamat Mengerjakan...

yang terhubung ke jaringan, di mana setiap device memiliki kunci enkripsinya sendiri, meningkatkan privasi dan keamanan secara signifikan.

Protokol SAE pada WPA3-Personal menggunakan mekanisme jabat tangan berbasis Diffie-Hellman yang menghasilkan shared secret unik untuk setiap sesi, berbeda dengan WPA2 yang memakai PMK statis dari PSK. Proses SAE terdiri dari fase commit untuk bertukar elemen kriptografi menggunakan elliptic curve atau finite field, lalu fase confirm untuk memastikan kedua pihak memiliki shared secret yang sama tanpa pernah mengirim password. Dengan desain ini, SAE memberikan forward secrecy sehingga sesi terdahulu tetap aman jika kunci di masa depan bocor, dan melindungi dari serangan pasif maupun offline dictionary karena penyerang tidak dapat menangkap handshake dan melakukan cracking seperti pada WPA2. Interaksi autentikasi harus dilakukan langsung dengan access point sehingga brute-force menjadi sangat terbatas dan serangan Man-in-the-Middle dapat dicegah karena kedua pihak perlu membuktikan pengetahuan password tanpa mengungkapkannya.

Meski WPA3 jauh lebih kuat daripada WPA2, beberapa skenario brute force tetap memungkinkan. Implementasi yang masih memakai metode Hunting and Pecking dalam elemen password SAE rentan terhadap serangan kamus dan waktu eksekusi sehingga H2E diwajibkan pada Wi-Fi 6E dan Wi-Fi 7. Transition mode yang mengizinkan fallback ke WPA2 membuka peluang downgrade attack karena penyerang dapat memaksa perangkat WPA3 beralih ke protokol yang lebih lemah. Password yang terlalu pendek atau mudah ditebak tetap rentan terhadap online guessing meskipun SAE membatasi frekuensi percobaan. Implementasi yang salah, penggunaan cipher yang kurang kuat, atau kelemahan perangkat seperti celah DragonBlood dapat memperluas permukaan serangan melalui side-channel atau exploit downgrade.

Untuk meningkatkan keamanan WPA3 tanpa mengganti protokol, beberapa langkah perlu diterapkan. Penggunaan H2E-only harus dipastikan agar proses elemen password tidak dapat dianalisis melalui timing attacks. Protected Management Frames harus diatur ke mode Required agar frame manajemen tidak dapat dipalsukan. Kebijakan kata sandi yang kuat minimal dua puluh karakter sangat penting untuk mencegah brute force jangka panjang. Lingkungan enterprise sebaiknya memakai WPA3-Enterprise dengan suite 192 bit dan autentikasi 802.1X berbasis RADIUS. Transition mode perlu dinonaktifkan secepat mungkin atau minimal diatur agar perangkat tidak pernah fallback ke WPA2 melalui fitur Transition Disable. Firmware access point harus diperbarui secara rutin untuk menutup celah seperti DragonBlood. Segmentasi jaringan, penggunaan WIDS atau WIPS, rate limiting percobaan autentikasi, serta pemantauan pola login yang tidak wajar dapat memperkuat perlindungan. Pengaturan VLAN, sertifikat 802.1X, dan kebijakan onboarding perangkat membantu membatasi akses dan memperkecil permukaan serangan.

Secara keseluruhan, WPA3 menciptakan lompatan besar dalam keamanan Wi-Fi dengan mengganti mekanisme PSK statis menjadi autentikasi berbasis SAE yang memberikan forward secrecy dan mitigasi terhadap offline cracking. Namun efektivitas WPA3 sangat bergantung pada konfigurasi yang benar, penghentian mode transisi, penggunaan H2E, serta pengawasan keamanan yang konsisten. Pendekatan berlapis seperti enforce H2E, mandatory PMF, password kuat, pembaruan rutin, serta monitoring aktif merupakan strategi optimal untuk memaksimalkan keamanan WPA3. Pada lingkungan modern seperti Wi-Fi 6E dan Wi-Fi 7 yang mewajibkan WPA3 dengan syarat lebih ketat, proses migrasi harus direncanakan dengan baik agar kompatibilitas perangkat dan kontinuitas operasional tetap terjaga. Keamanan akhir tidak hanya ditentukan oleh protokol, tetapi oleh implementasi yang tepat dan pemeliharaan berkelanjutan terhadap seluruh infrastruktur jaringan nirkabel.

5. Forensik Scanning Jaringan (C6-Sintesis)

Tim keamanan menemukan log yang menunjukkan aktivitas scanning ilegal.

- a. Rancang prosedur forensik untuk identifikasi sumber serangan.
- b. Simulasikan langkah mitigasi otomatis melalui IDS berbasis *signature & anomaly*.
- c. Sertakan pertimbangan hukum di Indonesia.

Indikator: Desain sistem IDS, analisis log, aspek hukum.

Bobot: Teori 30% – Aplikasi 70%

Jawab:

Ketika tim keamanan menemukan log yang menunjukkan aktivitas scanning ilegal dalam jaringan, prosedur forensik yang komprehensif harus segera dimulai untuk mengidentifikasi sumber serangan dan mengumpulkan bukti digital yang dapat dipertanggungjawabkan secara hukum. Tahap pertama dalam prosedur forensik adalah preservasi bukti digital dengan melakukan image atau snapshot dari log sistem yang terpengaruh, termasuk firewall logs, server logs, intrusion detection system logs, dan network traffic captures, untuk memastikan integritas data tetap terjaga dan chain of custody dapat dipertahankan. Analisis log harus dilakukan secara sistematis dengan mengidentifikasi anomali traffic patterns, seperti port scanning activities yang mencakup TCP SYN scans, UDP scans, atau comprehensive scans menggunakan tools seperti Nmap, serta mencatat timestamp, source IP addresses, destination ports, scan frequencies, dan payload signatures. Investigator harus melakukan correlation analysis dengan membandingkan multiple log sources untuk mendapatkan gambaran lengkap tentang attack timeline, menentukan apakah IP address penyerang merupakan actual attacker atau compromised host yang dijadikan proxy, serta melakukan reverse DNS lookup dan WHOIS queries untuk mengidentifikasi geographical location dan network ownership. Prosedur forensik juga mencakup memory forensics untuk mengidentifikasi malicious processes atau backdoors yang mungkin ditanamkan, disk forensics untuk menemukan artifacts seperti tools yang digunakan attacker, dan network forensics dengan melakukan deep packet inspection pada captured traffic untuk mengidentifikasi exploitation attempts atau data exfiltration. Dokumentasi harus detail dan mencakup screenshots, hash values dari evidence files menggunakan SHA-256 atau MD5, serta detailed timeline reconstruction yang menunjukkan sequence of events dari initial reconnaissance hingga potential compromise, dengan mempertimbangkan bahwa semua evidence harus memenuhi standar admissibility dalam proses hukum sesuai dengan ketentuan Pasal 5 UU ITE yang mengakui informasi elektronik dan dokumen elektronik sebagai alat bukti yang sah.

Simulasi langkah mitigasi otomatis melalui Intrusion Detection System berbasis signature dan anomaly memerlukan pendekatan hybrid yang mengkombinasikan kekuatan kedua metode untuk mencapai detection rate maksimal dengan false positive rate minimal. Pada layer signature-based detection, IDS harus dikonfigurasi dengan ruleset yang comprehensive mencakup signatures untuk common scanning tools seperti Nmap, Masscan, Zmap, dan Nikto, dengan rules yang mendeteksi characteristic patterns seperti rapid sequential port connection attempts, unusual flag combinations dalam TCP packets (NULL scans, FIN scans, XMAS scans), atau distinctive user-agent strings dari automated scanners. Sistem signature-based akan melakukan pattern matching terhadap known attack signatures dalam real-time, comparing incoming packets against database signatures yang harus di-update secara regular untuk mencakup latest threat intelligence, dan ketika match ditemukan, sistem akan generate alert yang berisi detailed information tentang detected threat termasuk signature ID, severity level, source dan destination information, serta recommended response actions. Complementing signature detection, anomaly-based detection system membangun baseline profile dari normal network behavior dengan memetakan typical traffic patterns, connection frequencies, protocol distributions, dan bandwidth usage selama learning period, kemudian menggunakan statistical analysis atau machine learning algorithms untuk mengidentifikasi deviations dari

Selamat Mengerjakan...

established baseline yang mengindikasikan suspicious activities seperti sudden spike dalam connection attempts, unusual port access patterns, atau abnormal data transfer volumes yang tidak consistent dengan legitimate business operations. Integrasi antara kedua metode menghasilkan Signature Anomaly Based (SAB) system yang memiliki akurasi deteksi lebih tinggi, dengan signature detection providing immediate response terhadap known threats sementara anomaly detection capturing novel atau zero-day attacks yang belum memiliki signatures. Automated response mechanisms harus dikonfigurasi dengan graduated responses berdasarkan threat severity: untuk low-severity events sistem dapat melakukan passive logging dan alerting, untuk medium-severity dapat melakukan rate limiting atau temporary blocking dengan automatic unblock setelah cooling period, sedangkan untuk high-severity threats sistem harus melakukan immediate blocking di firewall level, isolasi affected network segments, automated notification kepada security team melalui multiple channels (email, SMS, SIEM integration), dan triggering forensic data collection procedures. Sistem juga harus implement adaptive thresholds yang dapat adjust detection sensitivity based on network context, menghindari blocking legitimate vulnerability scanners dari authorized security assessments, serta maintaining audit trail dari semua automated actions untuk compliance dan post-incident analysis.

Pertimbangan hukum dalam penanganan kasus scanning jaringan ilegal di Indonesia harus merujuk pada Undang-Undang Nomor 19 Tahun 2016 tentang Informasi dan Transaksi Elektronik yang menjadi dasar pidana untuk berbagai aktivitas siber. Pasal 30 mengatur larangan akses ilegal dan langsung relevan dengan port scanning atau network reconnaissance tanpa izin karena tindakan tersebut dianggap sebagai upaya masuk ke sistem elektronik secara tidak sah. Pasal 31 mengatur intersepsi informasi elektronik sehingga dapat diterapkan pada aktivitas seperti packet sniffing atau perekaman traffic yang sering menyertai proses scanning. Jika scanning menyebabkan perubahan, kerusakan, atau penurunan fungsi data, Pasal 32 tentang data interference dapat berlaku, sedangkan gangguan terhadap ketersediaan atau operasional sistem dapat dijerat melalui Pasal 33 tentang system interference. Dalam aspek pembuktian, Pasal 5 menegaskan bahwa informasi elektronik dan dokumen elektronik merupakan alat bukti yang sah sehingga log, paket tangkapan, dan artefak digital yang diperoleh melalui prosedur forensik yang benar dapat digunakan dalam proses penyidikan maupun persidangan. Organisasi yang menjadi korban dapat melapor ke unit Cybercrime Polri atau PPNS Kementerian Komunikasi dan Informatika dengan menyertakan bukti digital yang telah dijaga integritasnya melalui chain of custody yang terdokumentasi. Yurisdiksi juga menjadi faktor penting karena Pasal 2 menetapkan bahwa UU ITE dapat diterapkan kepada pelaku di luar negeri selama efek perbuatannya terjadi di Indonesia sehingga memberikan kemampuan penegakan hukum secara ekstrateritorial. Ancaman hukuman berupa pidana penjara dan denda cukup signifikan, meskipun implementasinya menghadapi tantangan berupa kesulitan atribusi teknis, isu yurisdiksi lintas negara, dan keterbatasan sumber daya forensik di banyak daerah. Kondisi ini menunjukkan perlunya penguatan kapasitas aparat, penerapan standar forensik yang sesuai praktik internasional, serta peningkatan kerja sama global melalui mekanisme seperti mutual legal assistance treaties agar penindakan terhadap kejahatan siber lintas negara dapat berjalan lebih efektif.

7. Analisis IDS vs. IPS Modern (C4-Analisis)

Bandingkan IDS dan IPS dalam konteks jaringan enterprise modern.

- Jelaskan perbedaan fungsi deteksi dan respon otomatis.
- Analisis kapan IDS lebih efektif dibanding IPS.
- Usulkan kriteria pemilihan sistem untuk kampus besar seperti PENS.

 **Indikator:** Analisis komparatif, penerapan konteks nyata.

Bobot: Teori 50% – Analisis 50%

Jawab:

Selamat Mengerjakan...

Dalam jaringan enterprise modern, perbedaan utama antara Intrusion Detection System dan Intrusion Prevention System ada pada cara keduanya memproses dan merespons traffic. IDS bekerja sebagai sistem pemantauan yang bersifat pasif sehingga hanya menganalisis salinan traffic melalui mirror port atau network tap dan menghasilkan peringatan tanpa mengubah aliran komunikasi. Pendekatan ini tidak menambah latensi dan tidak berpotensi menjadi hambatan kinerja jaringan. Sebaliknya, IPS beroperasi secara aktif karena ditempatkan langsung di jalur traffic sehingga setiap paket harus melewatinya untuk diinspeksi. Dengan posisi ini, IPS dapat melakukan tindakan langsung seperti memblokir paket berbahaya, menghentikan sesi, atau memicu aturan firewall. Keduanya dapat menggunakan metode deteksi signature, anomali, dan kebijakan, namun perbedaan mendasar terletak pada mekanisme respons di mana IDS hanya memberikan alert sementara IPS dapat mengambil tindakan otomatis. Implikasi dari perbedaan ini sangat penting untuk desain arsitektur dan operasional karena IDS lebih fokus pada visibilitas dan analisis forensik sedangkan IPS menyediakan perlindungan langsung terhadap serangan yang bergerak cepat.

Perbandingan lebih lanjut menunjukkan bahwa IDS lebih efektif pada situasi yang membutuhkan fleksibilitas dan ketelitian analisis. Dalam lingkungan yang tidak toleran terhadap false positive seperti keuangan, layanan kesehatan, dan infrastruktur kritis, IDS lebih aman digunakan karena tidak memblokir traffic sah yang mungkin terdeteksi keliru oleh IPS. IDS juga lebih unggul untuk keperluan forensik dan threat hunting karena dapat melakukan inspeksi mendalam tanpa batasan latensi yang harus dipenuhi perangkat inline. Pada jaringan dengan bandwidth tinggi, IDS lebih mudah diskalakan dengan penempatan beberapa sensor tanpa menjadi titik kegagalan tunggal, sementara IPS yang inline dapat menjadi bottleneck jika tidak memiliki kapasitas besar. IDS juga mendukung kebutuhan audit dan pemantauan berkelanjutan yang sering diwajibkan oleh regulasi tanpa risiko perubahan traffic akibat pemblokiran otomatis. Dalam konteks riset atau laboratorium keamanan, IDS lebih fleksibel karena analis dapat menguji pola deteksi atau model perilaku tanpa khawatir mengganggu layanan produksi. Selain itu, IDS dapat menerapkan teknik analitik yang lebih kompleks yang tidak selalu cocok untuk proses inspeksi real-time.

Untuk institusi besar seperti PENS, pemilihan antara IDS, IPS, atau kombinasi keduanya harus mempertimbangkan karakteristik khusus lingkungan akademik. Kampus umumnya memiliki banyak segmen jaringan seperti jaringan administrasi, riset, mahasiswa, pusat data, IoT, dan jaringan nirkabel sehingga setiap segmen memiliki tingkat risiko dan kebutuhan keamanan yang berbeda. Segmen yang menyimpan data sensitif lebih cocok menggunakan IPS, sedangkan jaringan mahasiswa yang sangat dinamis dan padat traffic lebih aman dipantau dengan IDS agar aktivitas akademik tidak terganggu. Pertimbangan kapasitas dan performa juga penting karena kampus memiliki lonjakan traffic pada waktu tertentu sehingga solusi harus mampu menangani throughput tinggi tanpa menimbulkan latensi. Keterbatasan anggaran mendorong penggunaan solusi campuran seperti IDS berbasis open source yang melengkapi IPS komersial pada area paling kritis. Tingkat keahlian staf juga memengaruhi pilihan karena IPS memerlukan tuning lebih ketat untuk menghindari pemblokiran yang tidak diinginkan sehingga kampus dengan tenaga operasional terbatas dapat memulai dengan IDS terlebih dahulu sebelum memperluas penggunaan IPS. Tuntutan kepatuhan terhadap perlindungan data mahasiswa dan riset menuntut adanya pencatatan dan pemantauan menyeluruh yang secara alami difasilitasi oleh IDS. Pendekatan yang paling optimal biasanya berupa kombinasi berlapis dengan penggunaan firewall generasi terbaru yang memiliki modul IPS di perimeter, sensor IDS di berbagai segmen internal untuk visibilitas, serta perlindungan host pada server penting. Strategi implementasi dilakukan bertahap dengan membangun baseline melalui IDS, kemudian menerapkan IPS pada segmen prioritas, melatih staf keamanan, memperbarui aturan deteksi secara berkala, dan memanfaatkan kolaborasi komunitas akademik untuk meningkatkan ketahanan jaringan kampus.

9. Etika dan Hukum Cybersecurity (C5–Evaluasi)

- a. Jelaskan batas etika dan hukum dalam melakukan *penetration testing* di Indonesia.
- b. Evaluasi kasus “scanning tanpa izin” dari sisi hukum ITE dan etika profesional.
- c. Berikan contoh prosedur izin resmi yang sah untuk uji keamanan.

Indikator: Pemahaman hukum, analisis kasus, argumentasi etis.

Bobot: Teori 60% – Evaluasi 40%

Jawab:

Kegiatan *penetration testing* di Indonesia wajib mengikuti batas hukum yang diatur dalam Undang-Undang Informasi dan Transaksi Elektronik serta prinsip etika profesional yang berlaku dalam industri keamanan siber. Setiap bentuk pengujian keamanan hanya dapat dilakukan apabila telah ada izin tertulis yang sah dari pemilik sistem. Tanpa adanya otorisasi, aktivitas pengujian akan dianggap sebagai akses ilegal sesuai Pasal 30 UU ITE yang melarang setiap orang mengakses komputer atau sistem elektronik tanpa hak. Aktivitas yang umum dilakukan selama pengujian seperti mengumpulkan informasi, membaca data di jaringan, atau mencoba memodifikasi konfigurasi juga dapat masuk dalam kategori intersepsi atau perubahan data yang diatur dalam Pasal 31 dan Pasal 32. Gangguan terhadap kinerja sistem yang mungkin terjadi selama uji keamanan pun berpotensi memenuhi unsur Pasal 33 sehingga legalitas kegiatan ini sangat bergantung pada dokumen persetujuan resmi. UU ITE memiliki sifat ekstrateritorial sehingga pihak dari luar negeri yang menguji sistem milik entitas Indonesia tanpa izin tetap dapat ditindak. Dari perspektif etika, seorang *penetration tester* wajib memperoleh persetujuan eksplisit, menjaga batas lingkup pekerjaan, menjelaskan metode dan tujuan pengujian, serta melindungi data dan informasi yang ditemui selama proses tersebut. Selain itu, penguji keamanan harus bertindak dengan niat baik, menjaga profesionalitas, mematuhi standar kompetensi, dan menghormati privasi pengguna serta organisasi yang menjadi objek pengujian.

Scanning tanpa izin merupakan pelanggaran serius baik dari perspektif hukum maupun etika profesi keamanan siber. Dalam kerangka UU ITE, kegiatan ini dianggap sebagai upaya akses tanpa hak karena scanning pada hakikatnya merupakan proses menelusuri port, layanan, dan karakteristik teknis sistem yang tidak dapat dipisahkan dari aktivitas masuk ke ruang elektronik yang bukan miliknya. Meskipun scanning tidak selalu menyebabkan kerusakan sistem atau pencurian data, aparat penegak hukum dapat menafsirkan aktivitas tersebut sebagai tahap awal yang bertujuan mencari celah serangan sehingga termasuk tindakan yang dapat dipidana berdasarkan Pasal 30 dan Pasal 46. Ancaman hukuman semakin berat apabila scanning menyasar sistem vital seperti infrastruktur publik, layanan pemerintahan, atau platform yang menyimpan data pribadi sensitif. Dari sudut pandang etika, scanning tanpa izin melanggar prinsip penghormatan terhadap hak kepemilikan sistem, mengabaikan keharusan adanya persetujuan yang jelas, serta menunjukkan ketidakpatuhan terhadap kode etik profesi yang mengutamakan integritas dan tanggung jawab. Tindakan ini merusak kepercayaan antara praktisi keamanan dan organisasi, menimbulkan potensi gangguan operasional, dan dapat memberi dampak negatif bagi reputasi seluruh komunitas keamanan siber. Klaim bahwa scanning dilakukan untuk membantu atau untuk tujuan pembelajaran tidak dapat menjadi pembenaran etis maupun legal karena perbuatan tersebut tetap dilakukan tanpa mandat resmi dan berpotensi menimbulkan risiko pada pihak lain.

Izin resmi untuk melakukan pengujian keamanan harus dituangkan dalam perjanjian tertulis yang memuat penjelasan lengkap mengenai ruang lingkup, batas wewenang, dan tanggung jawab masing-masing pihak. Dokumen ini biasanya berupa kontrak formal antara penyedia layanan dan organisasi yang menjadi objek pengujian dan ditandatangani oleh pihak yang memiliki kewenangan hukum seperti kepala divisi teknologi informasi, pejabat keamanan informasi, atau perwakilan legal

Selamat Mengerjakan...

perusahaan. Dalam dokumen tersebut dijelaskan daftar sistem dan jaringan yang boleh diuji, metode dan pendekatan yang diizinkan, batas risiko yang dapat diterima, waktu pelaksanaan yang tidak mengganggu operasional penting, serta mekanisme eskalasi apabila ditemukan kerentanan kritis atau terjadi dampak tidak terduga. Selain itu, aturan pelaksanaan yang lebih rinci dituangkan dalam dokumen Rules of Engagement yang memberikan otorisasi eksplisit untuk melakukan tindakan teknis tertentu yang dalam kondisi normal dapat dikategorikan sebagai pelanggaran. Prosedur izin juga mencakup kewajiban kerahasiaan, tata cara penyimpanan data uji, koordinasi dengan tim operasional agar aktivitas pengujian tidak disalahartikan sebagai serangan, serta penentuan kontak darurat yang dapat dihubungi sewaktu-waktu. Setelah pengujian selesai, penguji keamanan harus menyerahkan laporan hasil penilaian, memberikan rekomendasi perbaikan, dan menghapus seluruh data yang dikumpulkan sesuai ketentuan yang disepakati. Struktur izin yang lengkap seperti ini memastikan bahwa kegiatan uji keamanan berlangsung secara legal, transparan, aman, dan dapat dipertanggungjawabkan.